

V0088

Advanced Information Security

高级信息安全

Instructor: **Prof. Xiaohong Yu**

Graduate School of Information and Communication Technology,

Ajou University, Korea

Outline

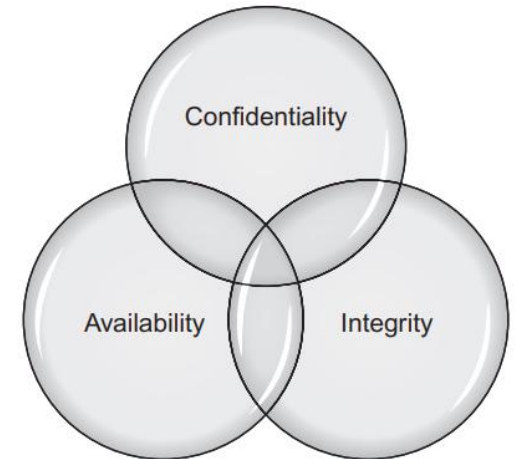
- **Introduction to Advanced Information Security** (高级信息安全简介)
- **Why This Course Matters?** (这门课程为何重要)
- **Real-World Security Incidents** (现实中安全事件)
- **Course Info. & Logistics** (课程信息和运营)

Introduction

- **Security:** the quality or state of being secure-to be free from danger.
- **Information Security:** to protect the **confidentiality**, **integrity** and **availability** CIA Triad of information assets, whether in storage, processing, or transmission. It is achieved via the application of policy, education, training and awareness, and technology.
- **安全:** 指免受危险侵害的品质或状态。
- **信息安全:** 指保护信息资产的**机密性**、**完整性**和**可用性**，无论信息资产处于存储、处理还是传输阶段。信息安全通过政策、教育、培训和意识提升以及技术手段来实现。

Introduction

- **Core principles of Information security**
- **The CIA Triad :**
 - **Confidentiality:** Ensures that sensitive information is kept secret and accessible only to authorized individuals.
 - **Integrity:** Guarantees the accuracy, trustworthiness, and reliability of data by preventing unauthorized modifications.
 - **Availability:** Guarantees that authorized users have reliable and timely access to information and resources.

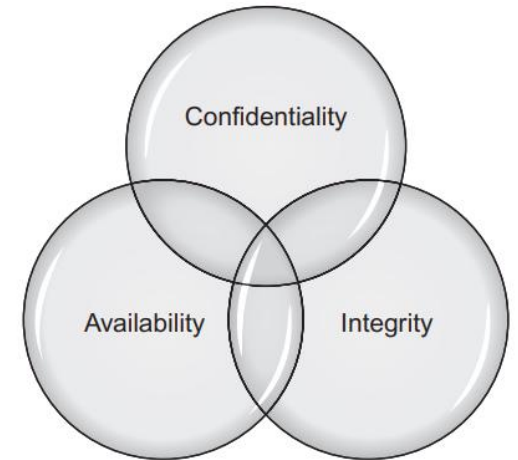


Introduction

- 信息安全的核心原则

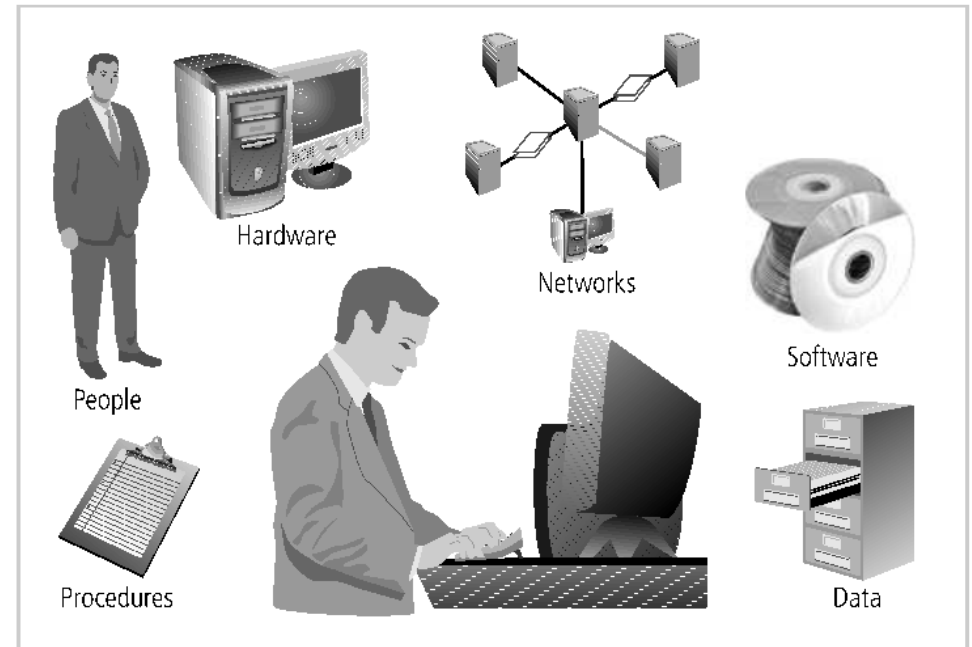
- CIA 三要素：

- 保密性：确保敏感信息保密，仅限授权人员访问。
- 完整性：通过防止未经授权的修改，保证数据的准确性、可信度和可靠性。
- 可用性：保证授权用户能够可靠、及时地访问信息和资源。



Introduction

- Security is not about Computers. 安全并非仅仅关乎计算机
- Security protects:
 - Business operations 业务运营
 - Trust relationships 信任关系
 - Economic value 经济价值
 - Human safety 人身安全



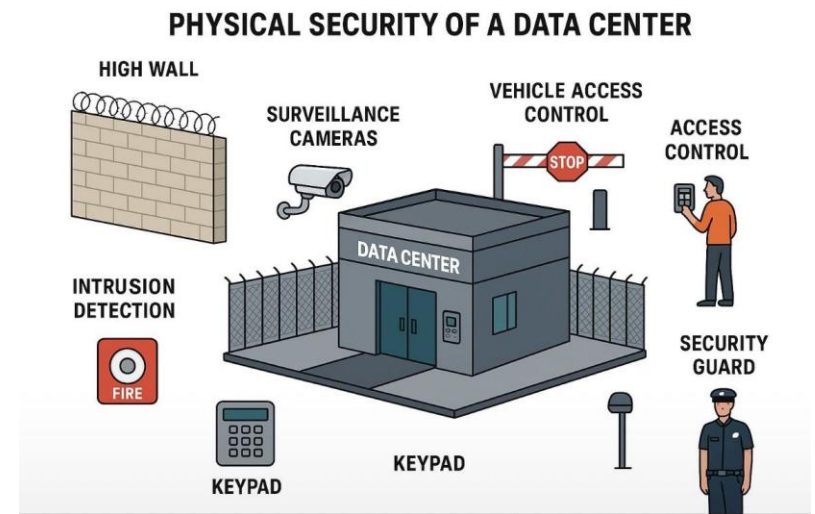
Components of an Information System

Introduction

A successful organization should have the following multiple layers of security in place to protect its operations:

- **Physical security**
- **Personnel security**
- **Operations security**
- **Communications security**
- **Network security**
- **Information security**

- 物理安全
- 人员安全
- 运营安全
- 通信安全
- 网络安全
- 信息安全



Introduction

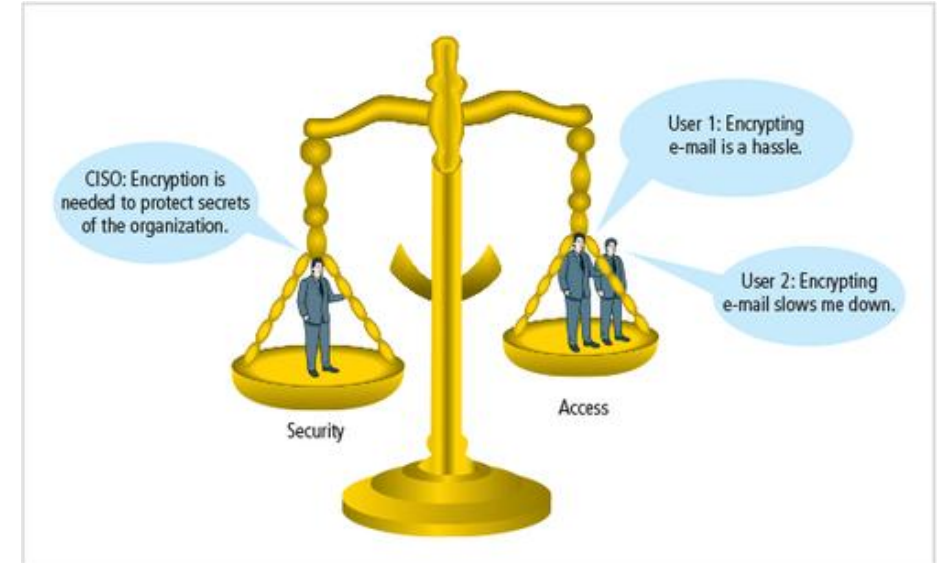
- **Security is Risk management**
 - Identify risk
 - Analyze risk
 - Reduces risk
 - Manages remaining risk
- 安全即风险管理
 - 识别风险
 - 分析风险
 - 降低风险
 - 管理剩余风险



那我们是否可以识别到的所有风险都采取风险管控措施？

Introduction

- **Security is a balance**
 - **Increasing security:**
 - Adds cost
 - Reduces usability
 - Impact performance
- 安全是一种平衡
 - 提高安全性：
 - 增加成本
 - 降低易用性
 - 影响性能



Introduction

- Most breaches involve: • 大多数安全漏洞都涉及:
 - Misconfiguration ➤ 配置错误
 - Poor decisions ➤ 决策失误
 - Social engineering ➤ 社会工程攻击

单靠技术无法解决安全问题。

Introduction

- **Security is :**

- Not a product
- Not a firewall
- Not encryption alone



- **Security is the discipline of managing risk in information system.**

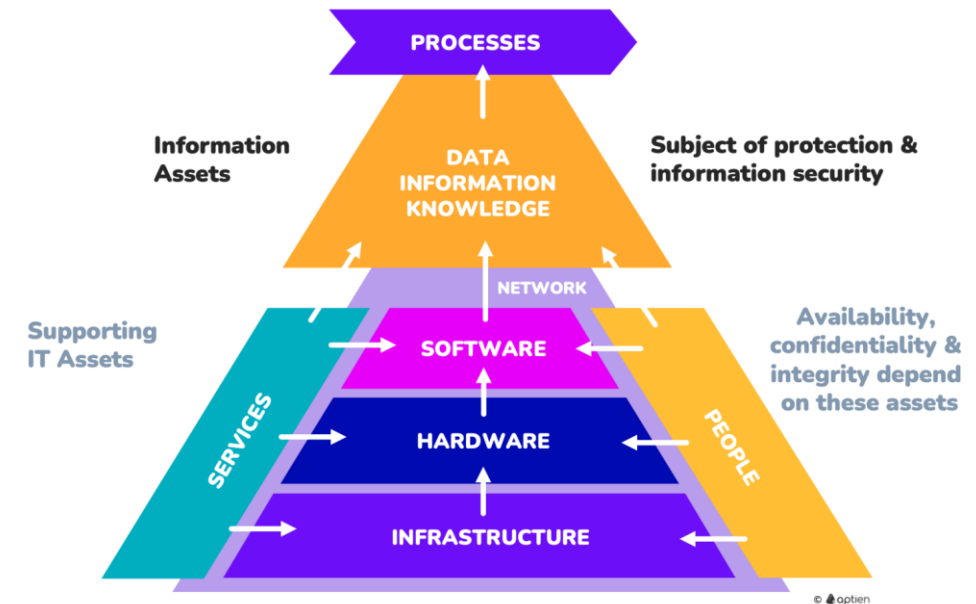
- **安全:**

- 不是一种产品
- 不是一种防火墙
- 也不仅仅是加密



- 安全是一个管理信息系统风险的学科。

Information Security Pyramid



Why This Course Matters?

- Every modern systems is software-defined
 - Every software system introduces risk
 - Organizations now treat information security as strategic risk.
-
- 所有现代系统都是软件定义的。
 - 每个软件系统都会带来风险。
 - 如今， 各组织都将信息安全视为战略风险。

Case study: Data Breach at Equifax

- Key Lessons:
 - A known vulnerability was unpatched
 - Attackers stayed inside for months
 - Millions of identities exposed
- 关键教训:
 - 已知漏洞未修复
 - 攻击者在系统内部潜伏数月
 - 数百万身份信息泄露

2017年9月，美国最大的征信机构之一Equifax对外宣布了一起影响1.48亿用户的网络安全事件。这是美国历史上最大的一起数据泄露事件之一，影响几乎一半的美国人口，政府将其总结为“这完全是一起可以避免的事故，但是Equifax并没有做好安全措施来保护用户的敏感数据”。

Equifax过分自信、过分自满的网络安全文化导致了这一切。Equifax未能修补已知的严重漏洞，使其系统面临145天的安全风险。公司未能实现基本的安全协议，包括文件完整性监控、网络分隔，使得攻击者访问和获取了大量数据。在攻击者获取数据的过程中，安全设备的证书过期19个月，又使得可以提前发现的攻击行为被掩盖。

Case study: Supply Chain Attack on SolarWinds

- Key Lessons:

- Attackers compromised software updates
- Customers installed malware willingly
- Trust relationships became attack vectors

- 关键教训:

- 攻击者利用软件更新漏洞
- 用户自愿安装了恶意软件
- 信任关系沦为攻击途径

当地时间2020年12月13日，FireEye发布了关于SolarWinds供应链攻击的通告，基础网络管理软件供应商SolarWinds Orion 软件更新包中被黑客植入后门，并将其命名为 SUNBURST，与其相关的攻击事件被称为 UNC2452。

SolarWinds的客户主要分布在美国本土，不乏世界500强企业。随着时间的推移，事件逐渐发酵，越来越多的事实正在被逐步发掘。本次供应链攻击事件，波及范围极大，包括政府部门，关键基础设施以及多家全球500强企业，造成的影响目前无法估计。

Case Study: Ransomware and Colonial Pipeline

- Impact:

- Fuel distribution halted
- National-level disruption
- IT incident → Physical-world

consequences

2021年5月7日，起源于美国得克萨斯州休斯敦、主要负责向美国东南部运输重油的石油管道系统科洛尼尔管道遭遇勒索软件网络攻击，影响负责管理管道的计算机系统^{[4][5][6]}。事发后，科洛尼尔管道暂停运作，全力应对袭击^{[7][8][9][10]}，17个州与华盛顿特区发布了区域紧急声明^[11]，以维持燃油供应。该事件是美国有史以来针对石油基础设施的最大规模网络袭击^[2]。联邦调查局及多家媒体证实黑客犯罪组织 DarkSide 策划了此次袭击^[12]，该团伙在发动袭击的前一天已从科洛尼尔管道公司的服务器偷走 100 千兆字节的数据^[1]。

- 影响:

- 燃料供应中断
- 全国范围的混乱
- IT 事件 → 实际影响

其他案例?

Case Study: Ransomware and Colonial Pipeline

- Impact:

- Fuel distribution halted
- National-level disruption
- IT incident → Physical-world

consequences

2021年5月7日，起源于美国得克萨斯州休斯敦、主要负责向美国东南部运输重油的石油管道系统科洛尼尔管道遭遇勒索软件网络攻击，影响负责管理管道的计算机系统^{[4][5][6]}。事发后，科洛尼尔管道暂停运作，全力应对袭击^{[7][8][9][10]}，17个州与华盛顿特区发布了区域紧急声明^[11]，以维持燃油供应。该事件是美国有史以来针对石油基础设施的最大规模网络袭击^[2]。联邦调查局及多家媒体证实黑客犯罪组织 DarkSide 策划了此次袭击^[12]，该团伙在发动袭击的前一天已从科洛尼尔管道公司的服务器偷走 100 千兆字节的数据^[1]。

- 影响:

- 燃料供应中断
- 全国范围的混乱
- IT 事件 → 实际影响

其他案例?

SK
Coupang

What these incidents have in common

- Failure in:

- Risk awareness
- Patch management
- Trust modeling
- Governance

- 不足之处:

- 风险意识
- 补丁管理
- 信任建模
- 治理

Course Info. & Logistics

Course Summary

- This course provide a comprehensive overview of protecting digital and non-digital data, focus on the CIA triad: Confidentiality, Integrity, and Availability.
- Key topics include risk management, legal/ethical issues, security policies, technology (firewalls, VPNs), and disaster recovery, emphasizing that security is a business management problem.
- 本课程全面概述了数字和非数字数据的保护，重点关注CIA三要素：保密性、完整性和可用性。
- 主要内容包括风险管理、法律/伦理问题、安全策略、技术（防火墙、VPN）和灾难恢复，并强调安全是一个业务管理问题。

Goal of This Course

- Understand the information security as a risk management discipline
 - Analyze real systems from an attacker and defender perspective
 - Apply core security principles to system design
 - Connect Technical issues to organizational and business impact.
-
- 理解信息安全作为风险管理学科的意义
 - 从攻击者和防御者的角度分析实际系统
 - 将核心安全原则应用于系统设计
 - 将技术问题与组织和业务影响联系起来。

Topics Covered (Tentative)

- Fundamental Principles (CIA Triad)
- Risk Management and security strategy
- Cryptography and Data Protection
- Physical, personnel and operational Security
- Access control and Identity management
- Network and infrastructure security
- System and application security

Topics Covered (Tentative)

- 基本原则 (CIA 三要素)
- 风险管理和安全策略
- 密码学和数据保护
- 物理安全、人员安全和运营安全
- 访问控制和身份管理
- 网络和基础设施安全
- 系统和应用安全

Course Information

- **Date & Time:** Thu. 14:00-16:50
- **Location:** 연암관 902
- **Lecture language:** Chinese in lecture, English and Chinese for slides
- **Office hour (In-person or online):**
 - **Time:** Tue. 15:00-16:00
 - **Office:** 연암관 922

课程信息

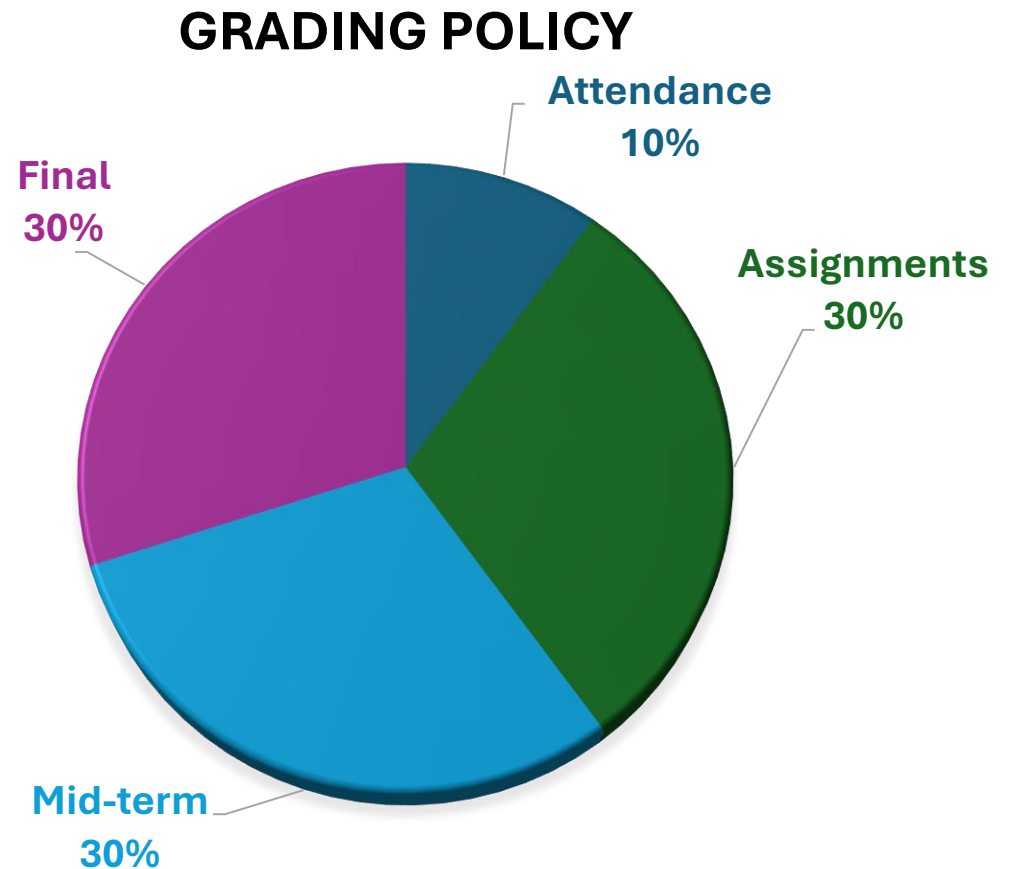
- 上课日期和时间: 每周四, 14:00-16:50
- 教室: 软岩馆 902
- 授课语言: 讲座为中文, 幻灯片以英文为主(中文辅助)
- 教授办公答疑时间 (面对面或者在线):
 - 时间: 每周二, 15:00-16:00
 - 办公室: 软岩馆922

Course Information

- **Evaluation Means:**

- Attendance;
- Assignments;
- Mid-term and final exams.

- **Grading Policy:**



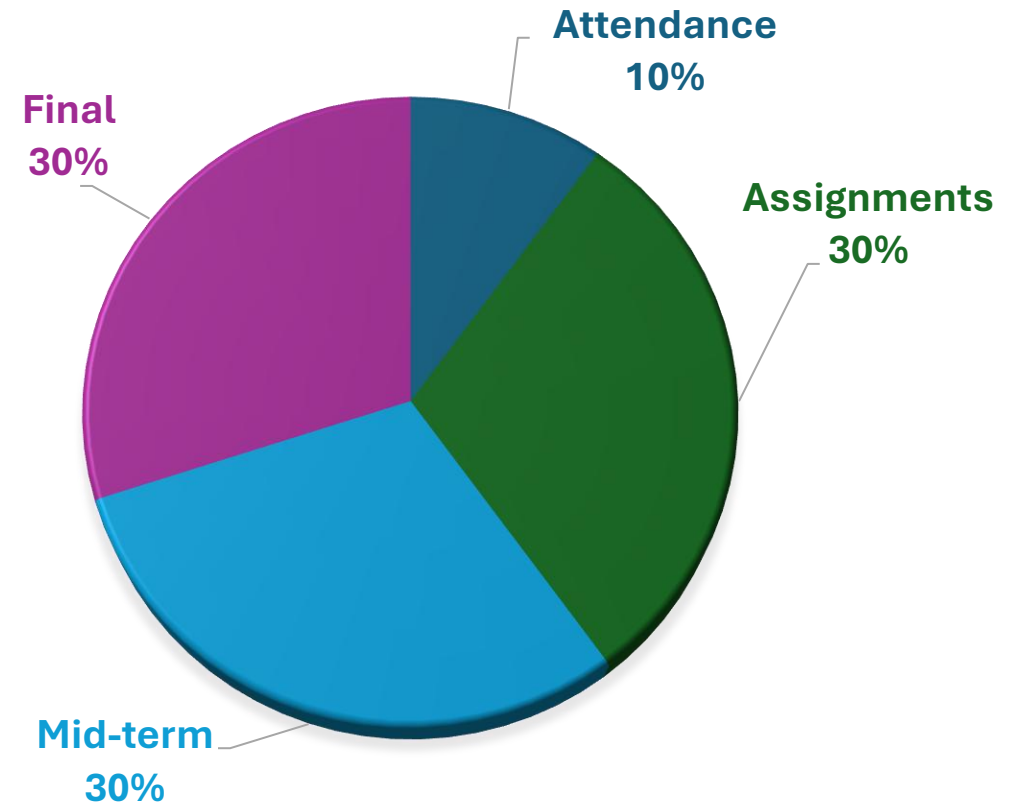
Course Information

- 评价方法:

- 出勤;
- 作业;
- 期中, 期末考试.

- 成绩评价策略:

GRADING POLICY



Course Learning Platform



- **Platform:** Ajou Blackboard (Bb)
 - Webpage: <https://eclass2.ajou.ac.kr/ultra/institution-page>
 - Android and iOS apps available (<https://linktr.ee/ajoubb>).
 - Lecture slides, materials, quizzes, assignments, etc. will be updated in Ajou Bb.
- **Questions and Answers**
 - Encourage to use the Ajou Bb to ask questions.
 - The instructor and the TA can try to answer your questions.
 - Your questions can also help others to improve their understandings.



QnA

Visible to students ▼

Please leave a question for this course.

Communications

- We use **Ajou Bb** and **email** for communications:
 - Please **specify the objective** of your questions.
 - ☐ **Good title**: How to use different parameters to read a csv file in python?
 - ☐ **Bad title**: Questions about the lecture
- Use **Chinese/English** for communications, questions in Ajou Bb, and all assignments.
 - If you use other languages, an English translation should be given.

交流方式

- 我们使用 Ajou Bb 和电子邮件进行交流：
 - 请说明您的问题的目的。
 - 好标题：如何在 python 中使用不同的参数读取 csv 文件？
 - 坏标题：关于讲座的问题
 - 如果使用电子邮件，请在电子邮件的某处清楚地输入您的姓名和学生证号，以便更容易的识别不同学生。
- 使用**中文/英文**进行交流、在 Ajou Bb 中提问以及完成所有作业。
 - 如果您使用其他语言，应提供中文/英文翻译。

Textbooks (Not mandatory)

- ***“Principles of Information Security”, Fourth Edition , Michael E. Whitman and Herbert J. Mattord 2011,***
• https://almuhammadi.com/sultan/sec_books/Whitman.pdf
- **“The Basics of Information Security: Understanding the Fundamentals of InfoSec in Theory and Practice ”,By Jason Andress, 2011,**
https://web.xidian.edu.cn/yanzheng/files/20160919_170521.pdf

Textbooks (Not mandatory)

- “信息安全原理与实践” by Mark Stamp, translated by Du Ruiying, 2007, <https://github.com/apacheecn/phei-cs-book/blob/master/%E4%BF%A1%E6%81%AF%E5%AE%89%E5%85%A8%E5%8E%9F%E7%90%86%E4%B8%8E%E5%AE%9E%E8%B7%B5.pdf>

Assignment

- **Assignments**

- We will have **2** assignments.
- Late submission penalty ***without*** early notice: **20% score deduction per day**.
- Late submission policy ***with*** early notice:
 - You can have up to **2 times** late submission chances without any reasons by sending a request **before** a deadline.
 - **Each** late submission can have an extension up to **2 days**.

作业

- 作业

- 我们将有 **2 次作业**。
- 未提前通知的延迟提交分数惩罚：每天扣除 **20% 的分数**。
- 提前通知的延迟提交政策：
 - 在截止日期前发送请求，您可以获得最多 **2 次无理由延迟提交** 的机会。
 - 每次延迟提交 **最多可延长 2 天**。

Attendance

- Use the Electronic Attendance System (EAS).
 - Guideline:
<https://www.ajou.ac.kr/kr/ajou/notice.do?mode=view&articleNo=326658&article.offset=0&articleLimit=10&srSearchVal=%EC%B6%9C%EC%84%9D>
- **4** absents (25%) -> **Fail**
 - **2** lates/early leaves -> **1** absent
- Absent by reasonable causes with proof:
 - Sick, military training, family causes, etc. In detail:
<https://www.ajou.ac.kr/kr/ajou/notice.do?mode=view&articleNo=324578&article.offset=0&articleLimit=10>
 - Submit a proper proof within 7 days after the absent **in EAS**.

出勤

- 使用**电子出勤系统**
 - 使用手册（韩文/英文）：
<https://www.ajou.ac.kr/kr/ajou/notice.do?mode=view&articleNo=326658&article.offset=0&articleLimit=10&srSearchVal=%EC%B6%9C%EC%84%9D>
- **4次缺勤 (25%) -> 挂科**
 - **2次** 迟到/早退-> **1次 缺勤**
- 因合理原因缺席并需提供证明：
 - 生病、军事训练、家庭原因等。详情：
<https://www.ajou.ac.kr/kr/ajou/notice.do?mode=view&articleNo=324578&article.offset=0&articleLimit=10>
 - 缺席后 7 天内在 EAS提交适当的证明，如医院诊疗记录，家庭关系证明等。

Attendance in EAS



아주대학교 통합 모바일

전자출석부 사용법

학생증 태그 방식 사용 불가

블루투스 비콘 인증방법

1 앱 다운로드

스토어 검색 창에 '아주대학교 통합 모바일'을 입력하여 모바일 앱을 다운로드

2 앱 실행

블루투스 및 위치서비스를 반드시 ON으로 설정!

3 출석 인증 전

강의 시작 15분 전부터 출결 화면이 실행됩니다. 강의실 내부에서 '출석하기' 버튼을 눌러주세요.

4 출석 인증 후

사용자의 GPS를 분석하여 강의실 내부일 경우에만 출석인증이 가능합니다.

인증번호 출석방법

5 인증번호 출석

인증번호 출석을 진행하는 경우, '인증번호' 버튼이 활성화됩니다. 인증번호 입력창으로 이동!

6 마무리

교수님이 지정한 인증번호를 입력한 경우, 출석으로 처리됩니다.

자세한 매뉴얼은 학교 공지사항 참조 (포털-공지사항-전자출결로 검색)

- **Attended: 15 mins before** and **15 mins after** the start time of a lecture.
 - BLE-based attendance checking by clicking in the smartphone App.
 - **Verification number**-based attendance checking.
- **Late:** 15 mins to 30 mins after the start time.
- Make sure to check your attendance status for each lecture in EAS.
 - **Any undefined status (미인증) will be absent.**

3/26/2026

Spring 2026

39

电子出勤系统



아주대학교 통합 모바일

전자출석부 사용법

학생증 태그 방식 사용 불가

블루투스 비콘 인증방법

1 앱 다운로드

스토어 검색 창에 '아주대학교 통합 모바일'을 입력하여 모바일 앱을 다운로드

2 앱 실행

블루투스 및 위치서비스를 반드시 ON으로 설정!

3 출석 인증 전

강의 시작 15분 전부터 출결 화면이 실행됩니다. 강의실 내부에서 '출석하기' 버튼을 눌러주세요.

4 출석 인증 후

사용자의 GPS를 분석하여 강의실 내부일 경우에만 출석인증이 가능합니다.

인증번호 출석방법

인증번호 출석

인증번호 출석을 진행하는 경우, '인증번호' 버튼이 활성화됩니다. 인증번호 입력창으로 이동!

마무리

교수님이 지정한 인증번호를 입력한 경우, 출석으로 처리됩니다.

자세한 매뉴얼은 학교 공지사항 참조 (포털-공지사항-전자출결로 검색)

- **出席：讲座开始前 15 分钟和开始后 15 分钟。**
 - 通过点击智能手机应用程序进行基于 BLE 的出勤检查。
 - 基于验证码的出勤检查。
- **迟到：开始后 15 分钟至 30 分钟。**
- 请务必在 EAS 中检查每节讲座的出勤情况。
 - 任何未定义状态 (미인증) 都将被视为缺席。

Mid-term and Final Exams

- **Mid-term**

- Format: closed-book written exam in class
- Date: **April 16^{ed}**
- Duration: **60 mins**

- **Final Exam**

- Format: closed-book written exam in class
- Date: **June 11th**
- Duration: **60 mins**

期中和期末考试

- **期中考试**

- 形式: 课堂内闭卷考试
- 日期: **4月16日**
- 时常: **60分钟**

- **期末考试**

- 形式: 课堂内闭卷考试
- 日期: **6月11日**
- 时常: **60分钟**

Don't Worry About Exams

- Most of students will pass the course.
 - 40% - 50 % will get A0 or A+.
- Don't work for exams, but for **the knowledge you will learn**.
- Ask questions, discuss with your classmates, work on assignments, review slides, check textbooks, etc.

LLM-based Tools Use Policy

- **No LLM-based tools** (e.g., ChatGPT and Gemini) are allowed to use in any **Assignments**, and **Exams**. (For assignments, you can refer to the tools but shall not directly copy the contents from them.)
- In case of **term project report**, if any texts are generated or modified by an LLM tool, **a statement shall be given** at the end of the report to describe where being modified by what kind of LLM tool and make sure the modified text follow the original intention of writing.

大语言模型工具的使用政策

- 任何测验、作业和考试**均不得使用**任何基于 LLM 的工具（例如 ChatGPT 和 Gemini）。（对于作业，您可以参考这些工具，但不得直接复制其中的内容。）
- 在学期项目报告中，如果任何文本是由 LLM 工具生成或修改的，则应在报告末尾**给出声明**，描述哪些地方被哪种 LLM 工具修改，并确保修改后的文本符合写作的初衷。

Academic Misconduct

- **Cheating**

- Cheating includes fraud, deceit, or dishonesty in an academic assignment, or using or attempting to use materials, or assisting others in using materials that are prohibited or inappropriate in the context of the academic assignment in question.

- **Plagiarism**

- Plagiarism includes use of intellectual material produced by another person without acknowledging its source.

- **False Information and Representation and Fabrication or Alteration of Information**

- Furnishing false information, failing to identify oneself honestly, fabricating or altering information and presenting it as legitimate, or providing false or misleading information to an instructor or any other University official in an academic context.

- **Theft or Damage of Intellectual Property**

- Sabotaging or stealing another person's work, improper access to or electronically interfering with the property of another person or the university, or obtaining a copy of an exam or assignment prior to its approved release.

- **Alteration of University Documents**

- Forgery of an instructor's signature, submitting an altered transcript of grades to or from another institution or employer, putting one's name on another individual's work, or falsely altering a previously graded exam or assignment.

学术不端行为

- **作弊**

- 作弊包括在学术作业, 考试中欺诈、欺骗或不诚实, 或使用或试图使用材料, 或帮助他人使用在相关学术作业, 考试中被禁止或不适当的材料。

- **剽窃**

- 剽窃包括使用他人制作的知识材料而不注明来源。

- **虚假信息 and 陈述以及捏造或更改信息**

- 提供虚假信息, 未能诚实地表明自己的身份, 捏造或更改信息并将其呈现为合法信息, 或在学术背景下向讲师或任何其他大学官员提供虚假或误导性信息。

- **盗窃或破坏知识产权**

- 破坏或窃取他人的作品, 不当访问或以电子方式干扰他人或大学的财产, 或在考试或作业获准发布之前获取其副本。

- **更改大学文件**

- 伪造教师签名、向其他机构或雇主提交更改后的成绩单、将自己的姓名写在他人的作品上, 或伪造之前评分的考试或作业。

Advanced Information Security

Thank you! Q/A?

Instructor: **Prof. Xiaohong Yu**

Graduate School of Information and Communication Technology,

Ajou University, Korea